

Programmation en C : Cryptanalyse

INSA DE STRASBOURG
MÉCATRONIQUE 3 - FIP-MIK4

Emmanuel Roussel
emmanuel.roussel@is1.eu

2020-2021

Introduction

Ce TD est une petite introduction à la cryptanalyse grâce à l'utilisation d'une fonction de hachage largement utilisée en cryptographie, appelée **SHA-256** (Secure Hash Algorithm).

De Wikipedia : "On nomme **fonction de hachage** une fonction particulière qui, à partir d'une donnée fournie en entrée, calcule une empreinte **unique** (ou signature, ou "hash") servant à identifier rapidement, bien qu'incomplètement, la donnée initiale. Les fonctions de hachage ont de nombreuses applications en informatique et en cryptographie." Il est très courant, par exemple, d'indexer des données par leur hash pour permettre un accès ou une recherche plus efficace et plus rapide (on parle de table de hashes). L'empreinte étant unique, c'est également un moyen de vérifier ou garantir l'intégrité des données : en cas de modification même mineure des données originales (erreur de transmission ou de téléchargement, acte malveillant, ...), le hash associé sera différent.

Fonction de hachage cryptographique

De manière plus spécifique, une fonction de hachage **cryptographique** est à sens unique : il est techniquement impossible en pratique de retrouver les données originales à partir du hash. C'est le cas de la fonction SHA-256.

Ces fonctions peuvent alors servir à apposer une signature électronique sur un document. On les utilise également pour l'authentification sans stockage du mot de passe : seul les hashes sont stockés et comparés. En cas de piratage, le pirate récupérera ainsi uniquement les hashes.

L'algorithme SHA-256

"L'algorithme SHA-256 fait partie de la famille de fonctions de hachage SHA-2 qui ont été conçues par la National Security Agency des États-Unis (NSA). SHA-256 est devenu le nouveau standard recommandé en matière de hachage cryptographique après les attaques sur MD5 et SHA-1. La fonction SHA-256 devient en 2002 un standard de traitement de l'information du gouvernement fédéral des États-Unis (Federal Information Processing Standard), dans le FIPS 180-2 (Secure Hash Standard). [...]". La fonction SHA-256 prend en entrée un message de taille arbitraire et produit un résultat (le hash) d'une taille fixe de 256 bits.

SHA-256 est largement utilisé aujourd'hui pour l'authentification, les certificats électroniques (les sites HTTPS par exemple), la signature numérique, etc. A ce jour, aucune attaque n'a montré de faille de sécurité sur cette fonction de hachage.

1 Objectif

Le tableau ci-dessous donne un ensemble de mots de passe cryptés grâce à l'algorithme SHA-256. Les mots de passe d'utilisateurs et d'autres données sensibles sont stockés de cette manière dans bon nombre de bases de données. Vous devez retrouver le mot de passe correspondant à chaque hash.

Hash	Mot de passe découvert
454349e422f05297191ead13e21d3db520e5abef52055e4964b82fb213f593a1fa690b82061edfd2852629aeba8a8977b57e40fcb77d1a7a28b26cba625912041cc4af005a69f3e80dbf0ab833d8b86d9d9c6ebfc40ba8b6c96503d265aefe6b21d0ec6f2ed95c050aabbba67c1e3ce78865199d200735498b377898d95e189f38f6c594ab58aad97993e44802be2491fc27bb00d1d6003ade56f2605c58b435	

Les hashes sont également donnés dans le fichier "password-database.dat".

2 Indications

Les mots de passe associés aux hashes donnés comportent uniquement des **lettres minuscules**.

1. Vous avez à votre disposition une librairie qui contient une implémentation de la fonction de hachage SHA-256. Compilez la librairie en utilisant le makefile fourni. La compilation va générer une bibliothèque (*library*) "libSHA256.a" que vous pouvez alors utiliser pour vos programmes¹.
2. Créez un programme permettant de calculer le hash d'une chaîne de caractère quelconque.
3. Créez un programme permettant de trouver le mot de passe correspondant au premier hash contenu dans le fichier "password-database.dat". Le mot de passe à trouver ne comporte qu'**une seule lettre**.
4. Modifiez votre programme pour trouver les autres mots de passe (de plus d'une lettre).
5. Modifiez votre programme pour traiter n'importe quelle longueur de mot de passe. Vous pourrez pour cela utiliser une fonction récursive.

1. Il faudra pour cela ajouter le fichier d'entête (.h) qui contient les prototypes des fonctions utilisables pour le compilateur et le fichier de code compilé de la bibliothèque (.a) pour l'éditeur de lien (*linker*).